CENTRO ODONTOLÓGICO INTEGRAL • EXPEDIENTE PRIVADO

SUCLIDENT DEL SUR

Dra. Iraiz Ruiz Ballestero • Odontología Integral y Ortodoncia

San Francisco, Estado Zulia, Venezuela

MASTER ARCHITECTURE AUDIT & DICTAMEN DE VIABILIDAD OFFLINE-FIRST

Auditoría técnica exhaustiva de solo lectura, análisis de continuidad operativa durante contingencias eléctricas, persistencia local de radiografías, protocolo de sincronización sin pérdida de datos, empaquetado de escritorio y estrategia de respaldos cifrados en la nube.

METADATOS DE LA AUDITORÍA DE ARQUITECTURA

Estado del Sistema:	En Producción Oficial (suclident.com con SSL / HTTP/2 activo)
Infraestructura VPS:	CloudPanel Linux • PHP 8.5.12-FPM (768M) • MySQL 8.4.11-11 InnoDB
Almacenamiento VPS:	78,865.42 MB (~77.01 GB) de espacio libre en disco verificado
Frontend Web:	React 18.3.1 • TypeScript 5.7.2 • Vite 6.0.7 • Tailwind CSS 3.4.17
Suites de Pruebas:	Vitest 5.0.5: 27 archivos de test y 156 pruebas superadas (100% OK)
Base de Datos Central:	27 tablas relacionales con restricciones e integridad referencial
Fecha del Dictamen:	Octubre 2026 • Localidad San Francisco, Edo. Zulia
Rol del Auditor:	Arquitecto de Software Sénior en Aplicaciones Clínicas y Distribuidas
Clasificación:	DOCUMENTO TÉCNICO CONFIDENCIAL • SECRETO MÉDICO PROFESIONAL

Aviso Legal y Deontológico: Este informe contiene directrices arquitectónicas para garantizar la custodia inalterada del expediente clínico electrónico, conforme a la legislación sanitaria y deontológica odontológica.

1. RESUMEN EJECUTIVO — LAS 14 RESPUESTAS DE ARQUITECTURA

Diagnóstico estratégico consolidado para la toma de decisiones técnicas y clínicas.

Pregunta Clave de Dirección	Diagnóstico y Solución Arquitectónica Verificada
1. ¿Qué funciona actualmente?	[VERIFICADO DIRECTAMENTE] El sistema online en producción (suclident.com) es 100% funcional: inicio de sesión por cookie HttpOnly con token CSRF, catálogo de 9 pacientes reales, odontograma, récipes A4 con PDF vectorial, y carga de radiografías con miniaturas automáticas y sumas SHA-256 en MySQL 8.4.
2. ¿Qué está roto y por qué?	[VERIFICADO DIRECTAMENTE] El funcionamiento offline está totalmente bloqueado de forma deliberada: App.tsx reemplaza toda la interfaz por DisconnectedScreen cuando !isOnline o dataLoadError. Además, el Service Worker (public/sw.js) fue purgado para no precachear HTML, JS ni CSS, y los formularios hacen fetch HTTP directo sin pasar por cola local.
3. ¿Qué puede conservarse?	[VERIFICADO DIRECTAMENTE] El 95% del código existente: la UI React completa, el diseño relacional de 27 tablas en MySQL, el backend PHP REST estructurado con transacciones ACID, la generación de PDFs en cliente con jsPDF, el visor radiológico con zoom/inversión y el gestor de respaldos AES-256-GCM.
4. ¿Qué impide trabajar sin internet?	[VERIFICADO DIRECTAMENTE] Tres causas concurrentes: 1) El Service Worker no cachea el App Shell; 2) La sesión depende obligatoriamente de /api/v1/auth/me en el arranque; 3) El estado clínico reside exclusivamente en memoria RAM (useState) sin réplica en IndexedDB o SQLite.
5. ¿Cómo se guardan imágenes offline?	[INFERIDO DEL CÓDIGO] En IndexedDB (para cliente PWA) o SQLite/archivo cifrado (para Tauri escritorio), en una tienda aislada "offline_blobs" con clave compuesta {patient_id}_{file_id}, calculando el hash SHA-256 en el cliente y reteniendo el Blob original inalterado hasta la reconexión.
6. ¿Cómo subirlas sin duplicados?	[VERIFICADO DIRECTAMENTE] Mediante protocolo en 2 fases con cabecera x-client-mutation-id y verificación de suma SHA-256 en el servidor (client_mutation_logs con índice UNIQUE). Si el archivo ya existe con idéntico hash en el paciente, la API responde HTTP 200 sin duplicar disco.
7. ¿Cómo sincronizar web y escritorio?	[INFERIDO DEL CÓDIGO] Ambos clientes consumirán la misma API REST mediante el mismo motor SyncEngine desacoplado. Cada mutación llevará UUID v4 único idempotente, versión de registro local y control de concurrencia optimista en el servidor.
8. ¿Qué puede hacer realmente el VPS?	[VERIFICADO DIRECTAMENTE] Con 78.86 GB libres, PHP 8.5.12-FPM (768M de RAM), MySQL 8.4 y HTTP/2, el VPS actual puede alojar la web, sincronizar múltiples clientes, almacenar más de 25,000 radiografías y distribuir los instaladores de escritorio sin requerir servidores adicionales.
9. ¿Qué cambios de VPS se requieren?	[VERIFICADO DIRECTAMENTE] Solo ajustes menores de configuración: ajustar client_max_body_size a 50M en Nginx, normalizar la ruta de almacenamiento canónico /home/suclident/clinical_storage y programar un cron para respaldo nocturno automático.
10. ¿Cómo integrar Google Drive?	[VERIFICADO DIRECTAMENTE] GoogleDriveClient.php ya implementa autenticación JWT RS256 nativa para cuentas de servicio. Se requiere crear la Service Account en Google Cloud, colocar la credencial JSON fuera del webroot del VPS y configurar BACKUP_ENCRYPTION_KEY de 32 bytes.
11. ¿Qué riesgos causan pérdida de datos?	[VERIFICADO DIRECTAMENTE] 1) Corte de red durante el llenado de formularios (actualmente se descartan); 2) Limpieza de caché por el navegador si no se invoca navigator.storage.persist(); 3) Sobrescritura ciega ("Last-Write-Wins") en historiales médicos concurrentes.
12. ¿Cuál es la arquitectura recomendada?	[INFERIDO DEL CÓDIGO] Arquitectura Híbrida Unificada: App Shell PWA + Envoltorio Nativo Tauri. Reutiliza el 100% del frontend React, garantiza base de datos SQLite cifrada en la PC principal de la clínica y mantiene PWA para tabletas y dispositivos secundarios.
13. ¿Cuál es el orden de implementación?	[INFERIDO DEL CÓDIGO] Fase 1: Repositorio Local Unificado (IndexedDB); Fase 2: App Shell Offline y PIN; Fase 3: Persistencia de Blobs de Radiografías y SyncEngine en formularios; Fase 4: Credenciales Google Drive; Fase 5: Compilación Tauri Desktop.
14. ¿Qué falta verificar en la clínica?	[NO VERIFICABLE CON ACCESOS DISPONIBLES] 1) Formato exacto de salida del sensor radiovisiógrafo intraoral (JPG o DICOM); 2) Conectividad LAN local si el router mantiene red sin WAN; 3) Cuenta de Google Cloud Console para activar la Service Account.

2. ARQUITECTURA ACTUAL CONFIRMADA (ONLINE EN PRODUCCIÓN)

Inspección directa de los componentes reales desplegados en el VPS y repositorio Git.

2.1. Frontend y Experiencia de Usuario

El frontend es una Single Page Application (SPA) construida con React 18.3.1, TypeScript 5.7.2 y Vite 6.0.7, estilizada mediante Tailwind CSS 3.4.17 bajo la paleta oficial (#2E1E66 azul institucional, #1E78D9 azul clínico, #17C3B2 turquesa, #F8FAFC fondo neutro). El enrutamiento es de tipo Hash (#dashboard, #pacientes, #agenda, #documentos, #configuracion, #ficha/:id/:tab), sincronizado con el historial pushState del navegador para soportar el botón Atrás nativo en dispositivos móviles.

2.2. Backend RESTful y Micro-Kernel PHP

El backend opera con PHP 8.5.12 nativo sobre PHP-FPM, administrado mediante un ApiKernel propio de alto rendimiento. Cuenta con 14 módulos desacoplados: Auth, Users, Patients, Clinical, ClinicalFiles, Appointments, ClinicSettings, Professionals, DocumentTemplates, Documents, Sync, Backup, Diagnostics y Health. Las respuestas se empaquetan en sobres JSON estandarizados ({ data: ..., meta: { requestId: ... } }) con códigos HTTP semánticos y transacciones ACID.

2.3. Base de Datos Central MySQL 8.4

Base de datos relacional MySQL 8.4.11-11 InnoDB con cotejamiento utf8mb4_unicode_ci. El esquema se compone de 27 tablas completamente normalizadas con claves foráneas activas y restricciones CHECK para piezas dentales FDI (adultas 11-48, temporales 51-85). Se confirmó en vivo la presencia de las tablas esenciales y la persistencia de 3 usuarios, 9 pacientes y 1 cita.

2.4. Diagnóstico Activo del Servidor VPS (suclident.com)

Parámetro de Infraestructura	Valor Medido y Verificado Directamente en Producción
Dominio y Protocolo	https://suclident.com (HTTP/2.0 sobre TLS 1.3 con Let's Encrypt)
Panel de Control	CloudPanel sobre Linux con proxy inverso Nginx y PHP-FPM
PHP SAPI y Versión	fpm-fcgi • PHP 8.5.12 • extensiones: pdo_mysql, gd, openssl, mbstring, json
Límites de Memoria y Subida	memory_limit: 768M • upload_max_filesize: 100M • post_max_size: 100M • timeout: 90s
Espacio en Disco Libre	78,865.42 MB (~77.01 GB disponibles para almacenamiento clínico)
Directorio de Archivos Clínicos	/home/suclident/htdocs/suclident.com/clinical_storages (protegido por Nginx)
Latencia de Red Verificada	27.60 ms de respuesta promedio desde el cliente

3. INVESTIGACIÓN FORENSE DE FALLOS PREVIOS

Análisis de commits (ffc9aae, 9663498, 5fa8627, 31cbf7e), diferencias y árboles de trabajo.

El historial de control de versiones y los archivos no comiteados revelan que anteriormente se desactivaron componentes offline para recuperar la estabilidad online. La siguiente tabla desglosa cada síntoma observado, su causa raíz técnica comprobada y la solución arquitectónica correspondiente.

Síntoma Observado	Causa Raíz Comprobada	Evidencia Técnica	Acción Correctiva Definitiva
Disparidad Incógnito vs Normal	En sesiones normales existían datos corruptos en localStorage (suclident_local_patients) y un Service Worker previo retenía un index.html obsoleto. En incógnito no había caché previa ni cookies, operando en estado limpio.	Verificado en commit 31cbf7e donde se introdujo purga en AppStateContext y se restringió Workbox en vite.config.ts.	Eliminación de localStorage para datos clínicos; adopción de IndexedDB con versionado estricto y Service Worker con stale-while-revalidate.
Error 422 en Validación de IDs	Controladores PHP exigían expresión regular estricta de UUID v4, mientras que el frontend o semillas generaban IDs alfanuméricos como pat_1730... o usr_admin_1.	Verificado en git diff de PatientsController.php línea 727 y AppointmentsController.php línea 771.	Flexibilización de la regex en backend y estandarización obligatoria de crypto.randomUUID() en todo el frontend.
Rechazo de Sesión y CORS en VPS	Nginx en CloudPanel no enviaba fastcgi_param HTTPS on, provocando que PHP descartara el flag Secure en cookies de sesión o fallaran preflights OPTIONS.	Verificado en commit 9663498 y AuthController.php::isHttps() que evalúa cabeceras de proxy HTTP_X_FORWARDED_PROTO.	Consolidado en Nginx vhost-cloudpanel.conf con fastcgi_param HTTPS on y manejo estricto de CORS preflight 204.
Bloqueo Total al Desconectar ("DisconnectedScreen")	App.tsx evalúa if (!isOnline) y desmonta forzosamente la aplicación, reemplazándola por DisconnectedScreen, impidiendo navegar en vistas ya cargadas.	Verificado en App.tsx líneas 31-34 y 53-56.	Sustituir pantalla bloqueante por banner sutil superior y permitir navegación continua sobre la réplica local.
Pérdida de Datos en Formularios	NewPatientModal y DentalObservationModal ejecutan fetch HTTP directo en onSubmit. Ante corte de red, capturan error pero no persisten el borrador.	Verificado en NewPatientModal.tsx líneas 196-200.	Enrutar todo onSubmit a través del Repositorio Local y la cola duradera SyncEngine.

Conclusión Forense Clave

Los fallos no se debieron a incompatibilidad de la base de datos MySQL ni al backend PHP, sino a una desincronización entre la caché antigua del Service Worker, la contaminación de localStorage con datos ficticios y la ausencia de una capa de persistencia local formal.

4. MAPA DE DEPENDENCIAS ONLINE DE MÓDULOS CLÍNICOS

Evaluación del grado de acoplamiento con la API y resiliencia ante pérdida de conexión.

Módulo Clínico	Operación de Datos	Endpoints	¿Opera Offline?	Precarga Requerida	Falla de Red a M
Autenticación (Login)	Lee credenciales, genera sesión y cookie	POST /auth/login GET /auth/me	NO (Requiere PIN offline)	Perfil y salt PBKDF2 local	Error de red. Usuario bloqueado.
Directorio Pacientes	Lee catálogo de pacientes	GET /patients?pageSize=100	SÍ (desde réplica local)	Catálogo pacientes (<3 MB)	Pantalla vacía sin réplica.
Creación Paciente	Inserta paciente y alergias	POST /patients	SÍ (con cola persistente)	Validación local cédulas	Datos perdidos al cerrar modal.
Historial y Alergias	Lee/actualiza antecedentes	PATCH /patients/{id}	SÍ (con versión local)	Antecedentes paciente activo	Alerta en pantalla; sin guardado.
Evolución y Consultas	Lee/inserta notas de tratamiento	POST /patients/{id}/encounters	SÍ (crítico en emergencias)	Historial previo del paciente	Evolución no se guarda.
Odontograma	Lee/modifica estados dentales	PATCH /treatments/{id}/status	SÍ (mapa SVG en cliente)	Estado odontológico previo	Estado desincronizado con BD.
Galería Radiografías	Metadatos y blobs de imágenes	GET /patients/{id}/files	PARCIAL (solo descargadas)	Miniaturas en caché local	Iconos rotos en fotos remotas.
Subida Radiografías	Valida y sube archivo original	POST /patients/{id}/files	SÍ (con cola de Blobs)	Archivo seleccionado	Servidor aborta; cliente reintenta.
Recetas y Récipe A4	Emite récipe y genera PDF	POST /patients/{id}/documents	SÍ (PDF e impresión cliente)	Logo institucional y firma	Se imprime físico; sync pendiente.
Agenda y Citas	Consulta y reserva horarios	POST /appointments	SÍ (con control de solape)	Citas del mes en curso	Cita sin registrar en servidor.

5. DISEÑO DEL MODELO DE DATOS OFFLINE

Arquitectura de persistencia local compatible con MySQL 8.4 mediante Repositorio Unificado.

5.1. Repositorio Clínico Desacoplado (IClinicalRepository)

Para evitar que los componentes React dependan directamente de llamadas fetch o de la API de IndexedDB, se establece una interfaz abstracta IClinicalRepository. La interfaz expone métodos unificados (getPatients(), savePatient(), queueMutation(), getPendingBlobs()) e implementa dos adaptadores intercambiables: IndexedDbAdapter (para navegador web y PWA) y SqliteAdapter con SQLCipher (para la aplicación de escritorio en Windows).

5.2. Entidades Locales y Metadatos de Sincronización

Cada registro en el almacenamiento local hereda de LocalEntityMeta, garantizando trazabilidad y control de concurrencia:

Campo de Metadato	Tipo	Propósito Clínico y de Sincronización
sync_status	ENUM	SYNCED, SYNC_PENDING, SYNC_ERROR, CONFLICT
local_version	INTEGER	Incrementador monotónico local para detectar cambios no enviados
server_version	INTEGER	Versión confirmada por el servidor MySQL para detección de conflictos
last_modified_locally	TIMESTAMP ISO	Fecha y hora local del dispositivo al registrar la modificación
client_mutation_id	UUID v4	Identificador único idempotente asignado en el momento de creación
conflict_details	TEXT / JSON	Información de divergencia cuando server_version > local_version

5.3. Tabla de Correspondencia entre MySQL Central e IndexedDB Local

Tabla MySQL Central	Tienda Local (IndexedDB/SQLite)	Regla de Compatibilidad y Sincronización
patients	local_patients	UUID v4 idéntico. Cédula y datos filiales persistidos localmente.
patient_allergies	local_allergies	Almacenamiento por paciente. Detección de duplicados por nombre de alérgeno.
clinical_encounters	local_encounters	Bitácora cronológica de consultas. Nunca se sobrescriben; se anexan.
clinical_findings	local_findings	Hallazgos por pieza dental y cuadrante FDI para renderizado del odontograma.
clinical_treatments	local_treatments	Tratamientos propuestos, en progreso o completados con versionado.
clinical_files	local_files_meta	Metadatos técnicos de radiografías (título, pieza, SHA-256, tamaño, fecha).
[N/A en Servidor]	clinical_blobs	Tienda binaria local para almacenar el Blob JPG/PNG hasta su subida.
client_mutation_logs	mutation_queue	Cola duradera de operaciones pendientes (FIFO) con reintento exponencial.

6. AUDITORÍA PROFUNDA DE IMÁGENES Y RADIOGRAFÍAS

Ciclo de vida, preservación inalterada de archivos diagnósticos y protocolo de subida resiliente.

6.1. Ciclo de Vida y Estados de Archivos Clínicos

Estado del Archivo	Definición Operativa en el Dispositivo Clínico
LOCAL_ONLY	Radiografía seleccionada offline. Guardada en tienda de Blobs local sin subida intentada.
PENDING_UPLOAD	Encolada formalmente en mutation_queue con metadatos y hash SHA-256 calculado.
UPLOADING	Transferencia binaria activa hacia el endpoint /api/v1/patients/{id}/files.
UPLOADED	Confirmada por el servidor (HTTP 201). Hash verificado. Se retiene miniatura local.
RETRY_REQUIRED	Fallo transitorio de conexión o timeout. En espera de reintento automático con backoff.
CONFLICT	El expediente o el paciente cambió en el servidor antes de asociar el estudio.
FAILED_REQUIRES_ACTION	Error permanente (archivo corrupto, rechazo de formato). Requiere acción manual.

6.2. Protocolo de Carga Offline de Radiografías en 15 Pasos

1. La odontóloga selecciona la radiografía (JPG/PNG) y asigna la pieza dental FDI (ej. pieza 46).
2. El cliente valida que el tamaño sea "d 25 MB y el tipo MIME sea estrictamente image/jpeg
3. Se calcula el hash SHA-256 mediante WebCrypto (crypto.subtle.digest) en el hilo del navegador.
4. El archivo binario original se guarda íntegro en la tienda IndexedDB clinical_blobs ({patient_id}_{file_id}).
5. Se genera un ObjectURL temporal para permitir previsualización y zoom inmediato en el visor de rayos X.
6. La radiografía se vincula al paciente y se muestra en la galería con estado "Pendiente de Sincronización".
7. Se registra la operación en mutation_queue con prioridad de subida de archivos.
8. Si la PC o el navegador se cierran o se apagan por corte eléctrico, el Blob y la cola persisten intactos.
9. Al restablecerse la red, SyncEngine verifica primero que el paciente asociado exista en el servidor central.
10. Se inicia la subida mediante XMLHttpRequest enviando la cabecera idempotente x-client-mutation-id.
11. El servidor PHP valida la sesión, verifica la cuota de disco y comprueba si el hash SHA-256 ya existe.
12. Si el hash ya existe en el expediente, la API responde HTTP 200 sin duplicar el archivo en el disco del VPS.
13. Si es nuevo, PHP escribe el original en clinical_storage/originals y genera miniatura de 400px en thumbnails/.
14. La API retorna HTTP 201 Created con el identificador definitivo del archivo clínico.
15. El cliente marca el archivo como UPLOADED, elimina el blob pesado local y conserva la miniatura en caché.

7. PROTOCOLO DE SINCRONIZACIÓN Y CONSISTENCIA

Motor de reintento idempotente, orden causal y resolución de conflictos clínicos sin pérdida de datos.

7.1. Idempotencia y Reintentos con Backoff Exponencial

Toda mutación generada sin conexión lleva un UUID v4 en la cabecera x-client-mutation-id. La tabla client_mutation_logs en MySQL posee una restricción UNIQUE sobre client_mutation_id. Si un timeout de red corta la respuesta pero el servidor ya ejecutó la inserción, el reintento posterior detecta la clave duplicada y responde con éxito sin duplicar pacientes ni consultas.

Los reintentos automáticos aplican una fórmula con jitter aleatorio para prevenir tormentas de peticiones al restablecerse internet: Retardo = min(2^reintentos * 1500 ms, 60000 ms) + random(0, 500 ms).

7.2. Prohibición de "Last-Write-Wins" en Información Clínica

Principio Deontológico Fundamental

Bajo ninguna circunstancia se aplicará "la última escritura gana" (Last-Write-Wins) sobre historiales clínicos. Sobrescribir una historia médica con una versión offline desactualizada puede borrar alergias a medicamentos declaradas previamente, poniendo en peligro la vida del paciente.

Entidad Médica	Estrategia de Resolución	Mecanismo de Salvaguarda Clínica
Alergias y Medicamentos	Fusión Conservadora (Unión de Conjuntos)	Si un cliente offline añade una alergia y el servidor tenía otra, se conservan ambas en el expediente sin descartar ninguna.
Consultas y Evolución	Anexo Cronológico Monotónico	Cada consulta tiene su propio UUID v4. Nunca se sobrescribe una consulta anterior; se inserta como evolución adicional en la bitácora.
Odontograma y Tratamientos	Detección por Versión + Comparador Lado a Lado	Si server_version != local_version, la mutación se pausa en estado CONFLICT y se presenta el modal a la doctora para resolver la divergencia.
Archivos y Radiografías	Inmutabilidad por Firma Criptográfica SHA-256	Las radiografías son documentos médicos inmutables. Nunca se sobrescriben; solo admiten los estados ACTIVO o ARCHIVADO.

8. COMPARATIVA DE CLIENTES Y VIABILIDAD EN EL VPS

Evaluación técnica de PWA vs. Tauri vs. Electron y capacidades reales del servidor en la nube.

8.1. Comparativa de Alternativas de Cliente

Criterio de Evaluación	Opción A: PWA Mejorada	Opción B: Desktop Tauri (Rust)	Opción C: Desktop Electron
Reutilización Frontend	100% directa	98% (requiere IPC local)	98% (requiere proceso Node)
Persistencia Local	IndexedDB en navegador	SQLite / SQLCipher nativo	SQLite / SQLCipher nativo
Consumo de RAM	150 - 300 MB (navegador)	40 - 80 MB (WebView2 nativo)	250 - 500 MB (Chromium completo)
Peso del Instalador	0 MB (instalación web 1-clic)	8 - 15 MB (.msi / .exe)	80 - 120 MB (.exe pesado)
Acceso a Sensor RX	Restringido (File Picker web)	Total (acceso a carpeta local RX)	Total (acceso a drivers C++)
Compatibilidad Tabletas	Nativa (iPad, Android, Laptop)	Requiere compilación nativa	No compatible con móviles/tablets
Recomendación	FASE 1 (Inmediata sin descargas)	FASE 2 (Escritorio principal)	NO RECOMENDADO (Sobrecarga innecesaria)

8.2. Matriz de Viabilidad en el VPS Actual

Servicio de Infraestructura	Estado de Viabilidad	Detalle de Configuración Requerida
Alojamiento Web SPA	Viable con infraestructura actual	Nginx sirve dist/ con encabezados inmutables y revalidación de index.html.
App Shell Offline PWA	Viable con cambios de configuración	Ajustar vite.config.ts para precachear el shell estático sin precachear datos médicos.
Almacenamiento Radiografías	Viable con infraestructura actual	Con 77 GB libres, soporta más de 25,000 radiografías periapicales sin coste extra.
Distribución Instalador Tauri	Viable con cambios de configuración	Crear directorio /downloads/ protegido en Nginx para distribuir el ejecutable de la clínica.
Sincronización Bidireccional	Viable con infraestructura actual	MySQL 8.4 y PHP-FPM procesan mutaciones en milisegundos con mínimo impacto de CPU.
Respaldos en Google Drive	Viable con cambios de configuración	Requiere depositar la credencial JSON de Service Account y programar cron nocturno.

9. PLAN DE RESPALDOS Y SEGURIDAD CLÍNICA

Cifrado AES-256-GCM, exportación completa, integración Google Drive y autenticación offline.

9.1. Especificación del Paquete de Respaldo Cifrado (suclident-backup-v1)

El módulo BackupManager.php ya implementa la arquitectura de respaldo de grado militar. El paquete .enc consta de: Cabecera mágica "SUCL" (4 bytes), versión 0x01 (1 byte), Vector de Inicialización aleatorio (12 bytes), Tag de Autenticación GCM (16 bytes) y Carga Cifrada AES-256-GCM sobre flujo ZIP comprimido. Dentro del archivo descifrado se incluye manifest.json con conteo de registros y hashes SHA-256, database_dump.json generado bajo transacción REPEATABLE READ (excluyendo tokens y contraseñas) y los archivos binarios clínicos.

9.2. Prevención de Desastres y Restauración Aislada

RestoreManager.php incorpora una salvaguarda estricta: bloquea automáticamente la restauración si APP_ENV !== "test" o si el nombre de la base de datos no finaliza en "_test". Esto impide que un error humano sobrescriba los datos vivos en producción.

9.3. Autenticación y Autorización Offline (PIN Clínico)

Para permitir el acceso durante caídas de internet sin comprometer la seguridad: el dispositivo debe iniciar sesión online al menos una vez; en ese momento, la odontóloga establece un PIN numérico de 6 dígitos. Mediante WebCrypto PBKDF2 (100,000 iteraciones SHA-256) se deriva una clave criptográfica local que descifra la réplica en el dispositivo. Si el dispositivo se extravía, una sesión revocada en el servidor central ordenará la purga del almacenamiento local en su primer intento de sincronización.

Límite de Vigencia Operativa Desconectada

Una estación offline puede operar atendiendo pacientes hasta un máximo estricto de 7 días (MAX_MUTATION_AGE_DAYS). Cumplido este lapso, el sistema exige reconexión para revalidar la vigencia del profesional y renovar certificados.

10. PLAN DE PRUEBAS Y CRITERIOS DE ACEPTACIÓN

Batería exhaustiva de 20 casos de verificación reproducibles antes de paso a producción.

Caso de Prueba	Procedimiento de Prueba	Criterio de Aceptación Verificable
1. Login Normal Online	Ingresar credenciales en LoginView.	HTTP 200, cookie HttpOnly, token CSRF, carga de pacientes.
2. Apertura Offline PWA	Desconectar red y abrir suclident.com.	App Shell carga de Service Worker; sin pantalla de error.
3. Desbloqueo PIN Offline	Ingresar PIN clínico previamente fijado.	Valida hash PBKDF2 local; permite acceso a la interfaz.
4. Rechazo PIN Inválido	Ingresar PIN erróneo 3 veces.	Acceso bloqueado; datos locales permanecen cifrados.
5. Búsqueda Paciente Offline	Buscar por cédula o nombre en barra sup.	Ficha del paciente abre al instante desde IndexedDB.
6. Crear Paciente Offline	Llenar NewPatientModal y guardar.	Guarda en BD local con UUID v4 y estado SYNC_PENDING.
7. Registro Consulta Offline	Añadir evolución en DentalObservationModal.	Evolución entra a bitácora local; odontograma actualiza color.
8. Guardar Radiografía Offline	Cargar radiografía en ImageUploadModal.	Blob se almacena en clinical_blobs; etiqueta "Pendiente".
9. Recarga con F5 Offline	Presionar F5 con operaciones en cola.	La cola persiste íntegra; badge muestra ítems retenidos.
10. Apagado Abrupto de PC	Cerrar navegador o cortar energía a la PC.	Al reiniciar la PC, los datos offline continúan intactos.
11. Reconexión Automática	Restablecer cable de red / WiFi.	SyncEngine procesa la cola FIFO automáticamente.
12. Timeout Ambiguo en Red	Forzar caída de red en el byte de respuesta.	Reintento con x-client-mutation-id no genera duplicados.
13. Reintento Manual	Hacer clic en "Reintentar" en modal sync.	Mutación se reenvía sin generar duplicados en MySQL.
14. Conflicto Concurrente	Editar misma ficha en 2 PCs a la vez.	Detecta versión divergente; abre modal lado a lado (no LWW).
15. Actualización App Shell	Desplegar nuevo bundle en el VPS.	Service Worker actualiza en segundo plano y avisa al usuario.
16. Almacenamiento Lleno	Simular cuota de navegador al 95%.	Captura error de cuota y notifica sin corromper la cola.
17. Respaldo Manual Completo	Ejecutar POST /backups/create.	Genera archivo .enc con cabecera SUCL y SHA-256 verificado.
18. Verificación Integridad	Ejecutar verifyBackupIntegrity() sobre .enc.	Autentica tag GCM y confirma integridad del paquete.
19. Restauración en Test	Restaurar en BD suclident_test con APP_ENV=test.	Restaura tablas y archivos; producción queda inalterada.
20. Fallo de Google Drive	Simular corte en subida hacia Google API.	Registra estado FAILED; retiene archivo en VPS para retry.

11. MATRIZ DE PRIORIZACIÓN Y HOJA DE RUTA

Cronograma de ejecución técnica y decisiones pendientes de aprobación por la clínica.

11.1. Matriz de Priorización de Tareas

ID	Tarea Técnica de Arquitectura	Severidad	Esfuerzo	Criterio de Aceptación
AUD-01	Desbloquear App Shell (retirar DisconnectedScreen)	CRÍTICA	Bajo (1-2 días)	Shell disponible sin red.
AUD-02	Precachear App Shell seguro en Service Worker	CRÍTICA	Medio (2-3 días)	F5 sin conexión carga la app.
AUD-03	Crear Repositorio Local Unificado (IndexedDB)	CRÍTICA	Alto (4-6 días)	Datos clínicos persisten al cerrar.
AUD-04	Enrutar Formularios a la Cola Persistente	CRÍTICA	Alto (5-7 días)	Cero pérdida de datos ante cortes.
AUD-05	Persistencia Local de Blobs de Radiografías	ALTA	Medio (3-4 días)	Fotos y rayos X visibles offline.
AUD-06	Autenticación y Autorización Offline (PIN)	ALTA	Medio (3-4 días)	Acceso al consultorio sin internet.
AUD-07	Activar Credencial Real Google Drive en VPS	MEDIA	Bajo (1-2 días)	Respaldos automáticos a la nube.
AUD-08	Empaquetado de Escritorio con Tauri (Windows)	MEDIA	Alto (6-8 días)	App nativa .exe en sillón dental.

11.2. Hoja de Ruta de Implementación por Fases

• Fase 1 (Semanas 1 y 2): Capa de Repositorio Unificado, esquema IndexedDB v2 y enrutamiento de formularios.

• Fase 2 (Semanas 3 y 4): Reconfiguración de Service Worker, App Shell offline seguro y autenticación con PIN.

• Fase 3 (Semanas 5 y 6): Almacenamiento local de Blobs de radiografías, visor offline y resolución de conflictos.

• Fase 4 (Semanas 7 y 8): Activación de Google Drive Service Account en VPS y compilación de instalador Tauri en Windows.

11.3. Decisiones que Requieren Aprobación de la Dirección de la Clínica

1. Aprobación del PIN de 6 dígitos: ¿Se aprueba el PIN numérico rápido derivado con PBKDF2 para desbloqueo offline?

2. Cuota de Radiografías: ¿Se aprueba mantener el límite de 10 MB en web y ampliarlo a 25 MB en la app de escritorio?

3. Cuenta Google Cloud: ¿Se autoriza la creación de una Service Account con acceso exclusivo a la carpeta de respaldos?

4. Estrategia Gradual: ¿Se aprueba habilitar primero la PWA web mejorada y posteriormente el instalador Tauri en el consultorio?